

تحلیل فنی و برنامه‌ی اصلاح آسیب‌پذیری‌های امنیتی

سامانه‌ی هدف: <https://asanet.isti.ir> – سامانه‌ی ارتباطات سازمانی مبتنی بر موتوشاب (Oxwall fork)

مبنای این سند: «گزارش آزمون نفوذ / ارزیابی امنیتی» مرکز تخصصی آپای دانشگاه محقق اردبیلی – تیر ۱۴۰۵

نوع این سند: تحلیل فنی مبتنی بر کد مخزن motoshub-web + برنامه‌ی رفع مستقل و backward-compatible

وضعیت: پیش از اجرا – منتظر تأیید مالک محصول برای پیاده‌سازی

۱. خلاصه‌ی مدیریتی

گزارش آپا روی سامانه‌ی asanet.isti.ir شش آسیب‌پذیری شناسایی کرده است: یک مورد بحرانی، سه مورد زیاد، یک مورد متوسط و یک مورد کم. در این سند، محل دقیق هر مورد در کد مخزن پیدا شده، سازوکار آن توضیح داده شده، راه‌حل حداقلی و سازگار با رفتار فعلی (backward-compatible) پیشنهاد شده، و اثر احتمالی هر اصلاح بر کارکرد موجود ارزیابی شده است. نکته‌ی کلیدی: هر شش اصلاح در فایل‌های کاملاً مجزا قرار می‌گیرند و هیچ همپوشانی‌ای ندارند؛ بنابراین می‌توانند به‌صورت شش Merge Request مستقل و کاملاً موازی روی شاخه‌ی main اعمال شوند.

#	آسیب‌پذیری	شدت (CVSS)	محل در کد	اثر بر کارکرد فعلی پس از رفع
۱	تزریق SQL در پارامتر photos[]	بحرانی – ۹.۸	→ photo/controllers/photo.php:844 photo/bol/photo_dao.php:2022	صفر
۲	XSS بازتابی در پارامتر endDate	زیاد – ۸.۲	view + iisquestionroles/.../report.php:2711 filter_date.html:20	صفر
۳	نقص کنترل دسترسی (IDOR) در گروه‌ها	زیاد – ۸.۱	groups/bol/service.php + endpoint داده‌ای گروه	ناچیز – با حفظ گروه‌های عمومی
۴	نبود محافظت در برابر Brute Force ورود	زیاد – ۷.۵	base/controllers/user.php:435	ناچیز
۵	نبود ویژگی SameSite روی کوکی نشست	متوسط – ۵.۵	ow_core/session.php:38	ناچیز
۶	افشای نسخه‌ی PHP در هدر پاسخ	کم – ۳.۳	سطح سرور / index.php / .htaccess	صفر

یادداشت دربارهی بررسی سایت زنده: در زمان تهیه‌ی این سند، سامانه‌ی asanet.isti.ir (آی‌پی 194.225.136.41) از محیط توسعه در دسترس نبود (اتصال TCP:443 تایم‌اوت و ۱۰۰٪ packet loss – احتمالاً محدود به شبکه‌ی داخل ایران). بنابراین مرور زنده‌ی رابط کاربری/رندر انجام‌نشده و همه‌ی تحلیل‌ها بر پایه‌ی سورس‌کد مخزن است، که سازنده‌ی همان سایت است.

۲. درباره‌ی سامانه (از روی سورس)

سامانه یک نصب سفارشی‌شده از پلتفرم شبکه‌ی اجتماعی **Oxwall/PHP** است (ساختار `ow_*`) که برای موتوشاب به‌شدت توسعه یافته: پلاگین‌های اختصاصی `iis*` (مانند `iisquestionroles` برای پرسمان و داوری، `iissecurityessentials` برای کدهای امنیتی عملیات، `iis subgroup`)، لایه‌ی `ow_iis`، یک `bridge/` و API نسخه‌ی جدید، به‌همراه `RabbitMQ` و `socket` و استقرار `Docker`. آسیب‌پذیری‌های گزارش‌شده هم در هسته‌ی `Oxwall` و هم در پلاگین‌های سفارشی پخش‌اند.

۳. تحلیل تفصیلی و راه‌حل هر آسیب‌پذیری

۱) تزریق SQL در `photos[]` بحرانی ۹.۸

مسیر: `POST /photo/photo/ajax-responder/` – بردار `CVSS:AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H`

چیست و کجاست: در `ow_plugins/photo/controllers/photo.php:844` تابع `getPhotoInfo()` آرایه‌ی `$_POST['photos']` را می‌گیرد و به `findPhotosInAlbum()` می‌دهد. در DAO، خط `photo_dao.php:2022` این شناسه‌ها را داخل عبارت `IN(...)` قرار می‌دهد. برخلاف ده‌ها کوئری دیگر همین فایل که شناسه‌ها را با `array_map('intval', ...)` پاک‌سازی می‌کنند (نمونه‌ی امن در خط ۲۰۳۸ همین فایل)، این مسیر پاک‌سازی عددی ندارد و آزمونگر توانسته فهرست نام دیتابیس‌ها را استخراج کند.

راه‌حل پیشنهادی: شناسه‌ی عکس همیشه عدد صحیح است؛ بنابراین در ورودی `getPhotoInfo()` (و سینک‌های پایین‌دستی) شناسه‌ها با `(int) / array_map('intval', ...)` نرمال شوند – دقیقاً همان الگوی امن موجود در خود فایل.

اثر بر کارکرد فعلی: صفر. مقادیر معتبر (عددی) بدون تغییر می‌مانند و فقط ورودی مخرب حذف می‌شود.

فایل‌های درگیر: فقط `ow_plugins/photo/` – شاخه: `security/sqli-photos-in-clause`

۲) XSS بازتابی در `endDate` زیاد ۸.۲

مسیر: `GET /iisquestionroles/report/detail?endDate=...` – بردار: `AV:N/AC:L/PR:L/UI:R/S:C/H/I:L/A:L`

چیست و کجاست: در `report.php:2711` مقدار خام `$_GET['endDate']` به قالب پاس داده می‌شود و در ویوی `views/components/filter_date.html:20` داخل `value="{ $endDate }"` بدون `escape` چاپ می‌شود. مهاجم با مقداری `endDate` می‌تواند از `attribute` بیرون بزند و کد جاوااسکریپت در بستر دامنه‌ی سامانه اجرا کند (سرقت کوکی نشست و محتوای صفحه). همین ورودی در `report_service.php:51` و `components/filter_date.php:119` نیز خوانده می‌شود.

راه‌حل پیشنهادی: دو لایه – (الف) خروجی در قالب `escape` شود (`{ $endDate|escape:'html' }`)، و (ب) در PHP مقدار به الگوی تاریخ محدود شود (فقط رقم و «-»). همین اصلاح برای `startDate` هم اعمال می‌شود.

اثر بر کارکرد فعلی: صفر. تاریخ معتبر جلالی (مثلاً 1405-04-31) پس از `escape` عیناً همان است.

فایل‌های درگیر: فقط `ow_plugins/iisquestionroles/` – شاخه: `security/xss-report-enddate`

۳) نقص کنترل دسترسی / IDOR در گروه‌ها زیاد ۸.۱

مسیر: تغییر شناسه‌ی گروه در URL – بردار: AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N

چیست و کجاست: طبق گزارش، با تغییر Group ID در URL، کاربر به فهرست اعضا و فایل‌های بارگذاری‌شده‌ی گروه‌های دیگر دسترسی می‌یابد. بررسی کد نشان می‌دهد مسیرهای اصلی (groups/controllers/groups.php – اکشن‌های view() و userList()) **بررسی مجوز isCurrentUserCanView()** را دارند؛ پس نشانی از یک endpoint داده‌ای/فایلی فرعی محدود‌ی گروه است که این بررسی را رد می‌کند. همچنین در groups/bol/service.php:1125 منطق isCurrentUserCanView برای گروه‌های «عمومی» (WCV_ANYONE) به‌عمد به همه اجازه‌ی دیدن می‌دهد و فقط گروه‌های «دعوتی» (WCV_INVITE) گیت اضافی دارند.

راه‌حل پیشنهادی: افزودن همان گیت isCurrentUserCanView(\$groupDto, true) به endpoint نشانی‌کننده (فهرست اعضا/فایل‌های گروه) در سمت سرور، مستقل از ورودی کلاینت.

⚠ **ملاحظه‌ی مهم backward-compat (تنها مورد حساس):** این اصلاح باید طوری انجام شود که گروه‌های عمومی (WCV_ANYONE) که عمداً برای همه قابل‌مشاهده‌اند همچنان باز بمانند و فقط نشانی دسترسی به گروه‌های محدود بسته شود. چون از همان تابع موجود سامانه استفاده می‌شود، رفتار گروه‌های عمومی حفظ می‌شود. مکان دقیق endpoint نشانی‌کننده سر پیاده‌سازی قطعی می‌شود (مسیرهای اصلی گروه امن بودند).

اثر بر کارکرد فعلی: **ناچیز و کنترل‌شده** – فقط دسترسی نشانی (که همان آسیب‌پذیری است) بسته می‌شود؛ مرور گروه‌های عمومی دست‌نخورده می‌ماند.

فایل‌های درگیر: فقط ow_plugins/groups/ – **شاخه:** security/idor-groups-access

۴) نبود محافظت در برابر Brute Force ورود زیاد ۷.۵

مسیر: فرآیند ورود – بردار: AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

چیست و کجاست: در base/controllers/user.php:435 تابع processSignIn() هیچ محدودیت نرخ یا قفل حساب ندارد؛ می‌توان بی‌شمار رمز امتحان کرد (اکشن ajaxSignIn() خط ۳۲۶). ضمناً رویداد ON_USER_AUTH_FAILED ارسال می‌شود اما پلاگین مصرف‌کننده (iisecurityessentials) در این نسخه‌ی مخزن حاضر نیست. گزارش همچنین به افشای نام‌کاربری اشاره دارد که احتمال حملات هدفمند را بالا می‌برد.

راه‌حل پیشنهادی: throttle سمت‌سرور خودکفا: شمارش تلاش‌های ناموفق بر اساس IP + نام‌کاربری و قفل موقت (و/یا CAPTCHA) پس از N تلاش در یک بازه‌ی زمانی. (مخزن هم‌اکنون captcha.php دارد).

اثر بر کارکرد فعلی: **ناچیز.** کاربر عادی متوجه نمی‌شود؛ فقط تلاش‌های پرتکرار ناموفق throttle می‌شوند. برای پرهیز از تأثیر بر کاربران پشت NAT مشترک، کلید IP+هویت و آستانه‌ی سخاوتمند انتخاب می‌شود.

فایل‌های درگیر: فقط ow_system_plugins/base/ – **شاخه:** security/login-brute-force-throttle

۵) نبود ویژگی SameSite روی کوکی نشست متوسط ۵.۵

بردار: AV:N/AC:L/PR:L/UI:R/S:U/C:L/I:L/A:L

چیست و کجاست: در ow_core/session.php:38 از فرم پنج‌آرگومانی session_set_cookie_params() استفاده شده که اصلاً SameSite ندارد (هرچند httponly و secure تنظیم شده‌اند). نبود این ویژگی سطح ریسک حملات CSRF/cross-site را بالا می‌برد.

راه‌حل پیشنهادی: تبدیل به فرم آرایه‌ای (PHP ۷.۳+) با افزودن 'samesite' => 'Lax'. **عمداً Lax نه Strict** – چون Strict می‌تواند ورود از طریق لینک‌های بیرونی/ریدایرکت‌های SSO را بشکند؛ Lax ناوبری معمولی سطح بالا را حفظ می‌کند.

اثر بر کارکرد فعلی: ناچیز. فقط درخواست‌های cross-site POST که به کوکی نشست تکیه داشتند تحت تأثیرند – که دقیقاً هدفِ سخت‌سازی CSRF است.

فایل‌های درگیر: فقط ow_core/session.php – شاخه: security/session-cookie-samesite

۶) افشای نسخه‌ی PHP در هدر پاسخ کم ۳.۳

بردار: AV:L/AC:L/PR:N/UI:R/S:U/C:L/I:N/A:N

چیست و کجاست: هدر X-Powered-By نسخه‌ی PHP را لو می‌دهد و به مهاجم برای انتخاب اکسپلویت منطبق کمک می‌کند.

راه‌حل پیشنهادی: حذف هدر با header_remove('X-Powered-By') در بوت‌استرپ + Header unset X-Powered-By در htaccess، و پیشنهاد expose_php = Off در php.ini سرور.

اثر بر کارکرد فعلی: صفر مطلق. رفتار برنامه تغییری نمی‌کند.

فایل‌های درگیر: فقط index.php و htaccess – شاخه: security/hide-php-version

۴. اثبات استقلال Merge Request ها

هر اصلاح در مجموعه‌ی فایل‌ی جدا قرار دارد و هیچ فایل‌ی بین دو MR مشترک نیست؛ بنابراین قابل‌بازبینی، merge و بازگردانی به‌صورت کاملاً موازی و مستقل‌اند:

MR	شاخه	مجموعه‌ی فایل (بدون همپوشانی)
SQLi	security/sqli-photos-in-clause	ow_plugins/photo/...
XSS	security/xss-report-enddate	ow_plugins/iisquestionroles/...
IDOR	security/idor-groups-access	ow_plugins/groups/...
Brute Force	security/login-brute-force-throttle	ow_system_plugins/base/...
SameSite	security/session-cookie-samesite	ow_core/session.php
PHP Version	security/hide-php-version	index.php، htaccess

۵. برنامه‌ی اجرا

- هر شش شاخه از `origin/main` ساخته می‌شوند؛ هر شاخه فقط یک اصلاح دارد و یک MR به سمت `main` می‌زند.
- هر کامیت MR/توضیح کامل اما مختصر دارد: آسیب‌پذیری، محل، تغییر، و تأیید `backward-compatible` بودن.
- منطق برنامه دست‌نخورده می‌ماند؛ فقط ورودی‌ها پاک‌سازی/گیت می‌شوند. هیچ قابلیت موجودی حذف نمی‌شود.
- **درباره‌ی ساخت خود MR:** میزبان `gl.iiscenter.ir` در دسترس است، اما ابزار `glab` نصب نیست و توکن GitLab نباید در URL/کانفیگ ذخیره شود. بنابراین یا با فراهم‌شدن دسترسی، شاخه‌ها `push` و MRها باز می‌شوند، یا شاخه‌ها/`patch` آماده می‌شوند تا مالک محصول MRها را باز کند.

۶. جمع‌بندی

هر شش مورد گزارشِ آپا قابل‌رفع و مستقل‌اند. پنج مورد (۱، ۲، ۴، ۵، ۶) اثر رفتاری صفر یا ناچیز دارند و کاملاً `backward-compatible`‌اند. تنها مورد ۳ (IDOR) ظرافت حفظ رفتار گروه‌های عمومی را دارد که با استفاده از تابع دسترسی موجود سامانه رعایت می‌شود. با تأیید مالک محصول، شش MR مستقل روی `main` آماده و اعمال می‌شوند و گزارش نهایی (شامل `diff`ها و لینک MRها) به‌روزرسانی خواهد شد.